

UNIVERSITÀ DEGLI STUDI DI SALERNO
DIPARTIMENTO DI INFORMATICA

Penetration Testing and Ethical Hacking

UniClass - PTEH Final Report



DATA: 27/09/2026

Indice

1	Introduzione	2
1.1	Contesto	2
1.2	UniClass	2
1.3	Obiettivo	2
2	Base del Processo Manutentivo	3
2.1	Change Request	3
2.2	Documentazione	3
2.3	Ciclo di Sviluppo - Grafico	4
3	Acceptance Testing Pre-Security Maintenance	5
3.1	FURPS Requirements	5
3.2	ASVS Requirements	6
3.3	Security Measurement	8
4	Acceptance Testing Post-Security Maintenance	10
4.1	Non-Functional Requirements	10
4.2	ASVS Requirements	11
4.3	Requisiti Esclusi e Risk Acceptance	12
4.4	SonarQube Analysis	14
5	AI-Usage	15

1 Introduzione

Questa sezione sarà utile per la comprensione del ciclo di sviluppo durante il processo manutentivo, dalla gestione della governance individuale applicata per regolamentazioni legali, convenzionali per la definizione delle attività necessarie per l'obiettivo del corso al termine e pubblicazione della piattaforma dopo l'accertamento del completamento delle procedure di sicurezza richieste nel Requirement Analysis Document (RAD) aggiornato con la totalità di requisiti definiti nella Change Request via mail (CR), SAMM framework e ASVS di livello 1.

1.1 Contesto

L'obiettivo del progetto del corso di Penetration Testing and Ethical Hacking è l'assimilazione e reificazione applicativa dei processi manutentivi per ridefinire l'aspetto sicuro di una Web Application pre-esistente.

1.2 UniClass

UniClass, come definito anche nei documenti allegati, è una Web Application che prende piede come progetto dell'esame di Ingegneria del Software e, successivamente, per motivi differenti ma pur per processi manutentivi adattivi, correttivi o migliorativi, per i seguenti esami:

- Software Dependability - Per CI/CD pipelines, processi di sicurezza bloccanti per l'aggiornamento della Master Repository, alto livello e definizione di requisiti di testing, modeling languages e misura dell'affidabilità dell'applicazione.
- Sustainable Software Engineering - Per il monitoraggio e avanzamento della sostenibilità della Web Application in tutti i suoi aspetti sociali, tecnici, economici e ambientali con motivazione e ridefinizione nella codebase, architettura o documentazione.
- Ingegneria del Software Tecniche Avanzate (ISTA) - Per la comprensione degli standard IEEE 12207, 828, 829 (rispettivamente per la reificazione e attuazione di gestione di processi manutentivi, configuration management e testing).

L'aspetto importante che è stato messo da parte durante questi processi di refactoring è proprio quello della sicurezza che, nonostante la messa a disposizione di meccanismi bloccanti, revisione e monitoring in tempo reale di vulnerabilità (di sicurezza e non) e dipendenze, non è stato visionato completamente un vero processo di sicurezza. Pertanto, per motivi educativi, sarà utilizzata la versione migliorata dell'esame di ISTA, escludendo le migliori presenti nei restanti due esami.

1.3 Obiettivo

L'obiettivo non sarà una semplice integrazione di pipeline CI/CD con GitHub actions di monitoring delle vulnerabilità presenti. Data l'importanza del corso e la combinazione del curriculum Software Engineering and IT, si decide di determinare un vero processo

manutentivo dall'inizio alla fine attraverso parte documentale, reporting completo, definizione delle modifiche con razionale, aggiunta di requisiti e modalità e definizione delle procedure di testing.

2 Base del Processo Manutentivo

Si determina quindi la base del processo manutentivo, ovvero le linee guida, raccomandazioni e procedure stabilite per la reificazione dei processi di sicurezza presenti nei framework open più famosi e standardizzati, sia in ambito educativo, che in ambito lavorativo.

2.1 Change Request

La Change Request introdotta via mail, come vera e propria proposal e idea del progetto, definisce dei veri e propri macro-requisiti per la struttura del ciclo di sviluppo di correzione, adattamento e miglioramento della piattaforma UniClass. Infatti, si citano gli ASVS [1] (v5.0) per l'aggiunta di requisiti di sicurezza di primo livello su tre (essendo un progetto d'esame) sulla base di 17 diversi contesti d'applicazione e aspetti di sicurezza; quest'ultimi saranno determinanti per la fase di testing pre e post sviluppo manutentivo per misurare l'incremento della sicurezza dell'applicazione, attraverso il Web Security Testing Guide [2]. Inoltre, si è deciso di gestire la parte manageriale, documentale, pratica ed economica della piattaforma attraverso il framework di maturità SAMM [3], da cui si avranno ulteriori requisiti. Il RAD sarà aggiornato con i requisiti definiti nell'ASVS, nel SAMM e nella CR.

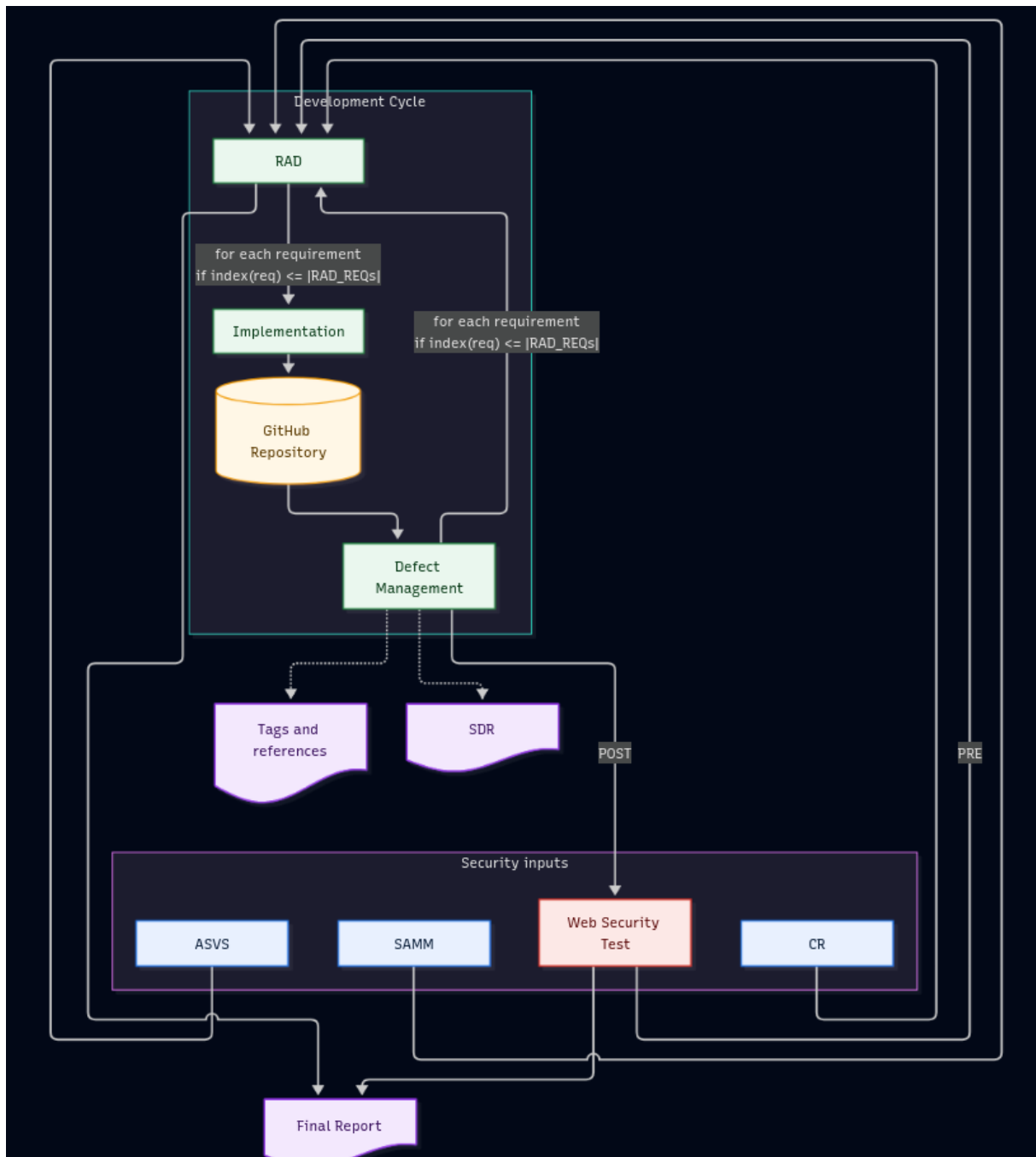
2.2 Documentazione

Nella parte documentale, è possibile visionare diversi aspetti riguardanti lo sviluppo e l'esecuzione delle procedure di sicurezza definite. In particolare:

- **RAD:** Il *Requirement Analysis Document* aggiornato alla versione 2.0 avrà un'aggiunta di requisiti di manutenibilità, affidabilità e sicurezza. I requisiti aggiunti, che verranno poi testati, sono: **ASVS Level 1 Requirements**, **NFR4**, **NFR8**, **NFR9**, **NFR10**, **NFR11**, **NFR12**, **NFR13**, **NFR14**, **NFR15**, **NFR16**, **NFR17**, **NFR18**.
- **SAMM:** Il *Framework di Software Assurance Maturity Model* di OWASP definisce la gestione manageriale del ciclo di sviluppo manutentivo, oggetto d'esame.
- **DM:** Il *Defect Management* avrà il ruolo fondamentale di descrivere, per ogni procedura di sicurezza seguita e, di conseguenza, ogni refactoring per migliorare l'aspetto principe del progetto, ci sarà un insieme di Security Design Records (SDR) e/o eventuali Architectural Design Record (ADR) con determinazione di titolo, descrizione, razionale, codebase prima e dopo (e/o eventuale corrispondente per livello d'astrazione diverso da quello implementativo), eventuale riferimento al requisito presente nel RAD ed eventuale identificativo nel Web Security Testing Guide.

- **Final Report:** Il *Final Report* controllerà l'intera parte documentale e manageriale di ciò che è stato definito e sviluppato durante il ciclo di sviluppo manutentivo. Sarà possibile visionare Il *Pre* e il *Post* del Software da ogni punto di vista possibile (se intaccato dal refactoring)

2.3 Ciclo di Sviluppo - Grafico



3 Acceptance Testing Pre-Security Maintenance

In questa sezione, si definirà il risultato del testing dei requisiti aggiunti nella versione 2.0 del documento di UniClass, secondo il Configuration Management del sistema, sulla base del Web Security Testing Guide [2]. Si creano così delle basi per il documento *Defect Management* che conterrà, in sintesi, la descrizione e l'identificativo per ogni difetto o problematica di sicurezza con relativa successiva risoluzione, che verrà testata nel Post-Security Maintenance Process, come definito nel Development Cycle del grafico 2.3

La struttura sarà una tabella con le seguenti informazioni:

- **ID** - Identificativo univoco presente nel RAD
- **Esito** - Successo o Failed per l'esito del test effettuato. WIP (Work in Progress) se e solo se, per il soddisfacimento del requisito, è previsto un task per tutto il ciclo di sviluppo manutentivo.
- **Testing Method** - Mezzo utilizzato per verificare il soddisfacimento del requisito preso in considerazione; e.g. Euristica, Performance Testing, ...
- **Note** - Annotazioni facoltative sul requisito, sul testing method o sull'esito

3.1 FURPS Requirements

Effettuiamo l'Acceptance testing per i requisiti stabiliti nella sezione FURPS del RAD, escludendo quindi gli ASVS - LEVEL1.

ID	Esito	Testing Method	Note
NFR4	Fallito	Code Review	Non implementato
NFR8	Successo	Git Logs	Le conventions si sono già utilizzate in passato e si continuerà l'uso. Inoltre si è creato un tag di start
NFR9	WIP	//	Si userà il <i>DM</i> per questo motivo
NFR10	WIP	//	Non vi sono ancora degli updates relativi alla codebase o architettura
NFR11	WIP	//	Si stanno già usando conventions
NFR12	WIP	//	Non vi sono ancora updates relativi alla codebase o architettura
NFR13	Fallito	//	Vi sono actions per Snyk ma non vi è alcun modo per visualizzare i risultati
NFR14	Fallito	//	Non vi è ancora alcuna Security Policy
NFR15	Successo	SonarQube Cloud	//
NFR16	Fallito	GitHub Actions Repository	Al momento vi sono delle actions ma non vi è alcun modo di visionare in tempo reale lo stato del sistema
NFR17	Successo	GitHub Actions, SonarQube Cloud	//
NFR18	Successo	GitHub Actions	//

3.2 ASVS Requirements

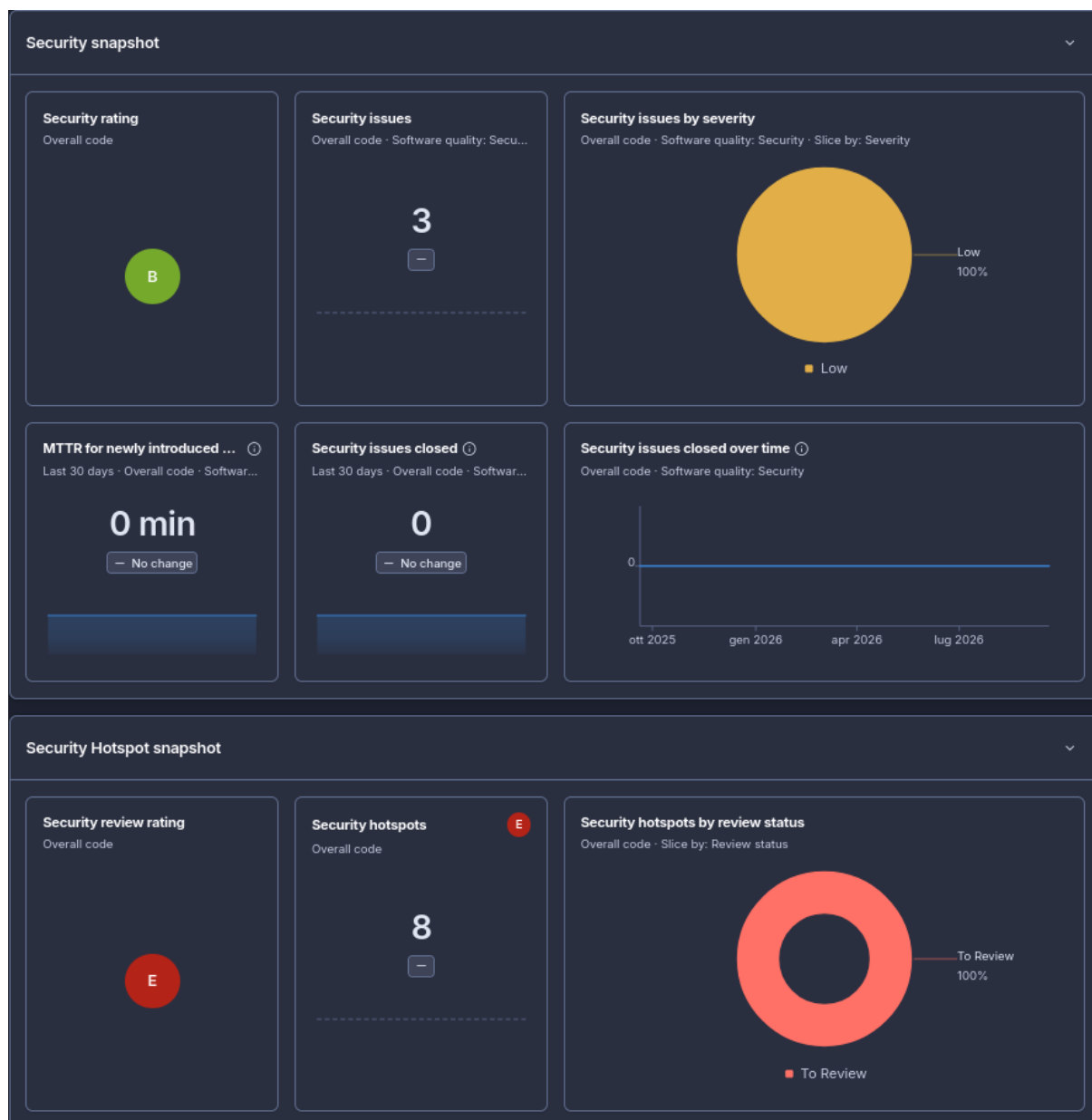
Effettuiamo l'Acceptance Test per gli ASVS di livello 1. Saranno effettuati mediante eventuale linee guida del documento di riferimento [2] o euristica. Ogni vulnerabilità verrà inserita automaticamente nel *Defect Management*. *Nota: come descritto anche in Defect Management, se il test è stato automatizzato, verrà scritto "Automated Test", considerando quindi i test di security nella repository pubblica*

ID	Esito	Testing Method	Note
1.2.1	Fallito	WSTG-INPV-01/02	Tramite la chat è possibile non visualizzare solo testo, bensì anche formattazioni o contenuti speciali
1.2.2	Fallito	WSTG-INPV-02	Tramite l'url è possibile iniettare script
1.2.4	Successo	WSTG-INPV-05	X
1.2.5	Successo	WSTG-INPV-12	X
1.3.1	Fallito	WSTG-INPV-02	In Chat si possono mostrare sia blocchi che alert (script)
1.3.2	Successo	WSTG-CLNT-02	Non presente alcun eval o possibilità di esecuzione di codice dinamica
1.5.1	Successo	WSTG-INPV-07	Nessun problema con i parser XML
2.1.1	Successo	Documentazione	Nei TP e TCS è possibile visionare valori delle variabili e conseguente stato
2.2.2	Fallito	CURL	Manca il change della session
2.3.1	Successo	CURL	X
3.2.1	Fallito	Dev-Tools	Sempre stesso jsessionid
3.2.2	Fallito	WSTG-INPV-02	Stesso test del precedente
3.3.1	Fallito	Automated Test	Cookie di sessione senza flag secure
3.4.1	Fallito	Automated Test	Strict-Transport-Security non presente
3.4.2	Successo	Automated Test	X
3.5.1	Fallito	WSTG-SESS-05	Non valida CSRF
3.5.2	N/A	X	Nessun preflight
3.5.3	Fallito	WSTG-INPV-06	Viene usato doGet anche con doPost e viceversa per non fallire mai (ma falla di sicurezza conseguente)
4.1.1	Fallito	Automated Test	Content-Type sicuro non presente
4.4.1	Successo	WSTG-CONF	X
5.2.1	Successo	WSTG-BUSL-08	UniClass non prevede upload
5.2.2	Successo	WSTG-BUSL-08	UniClass non prevede upload
5.3.1	Successo	WSTG-BUSL-08	UniClass non prevede upload
5.3.2	Successo	WSTG-BUSL-08	UniClass non prevede upload
6.1.1	Fallito	Documentazione	UniClass non prevede rate limiting o anti-automazione
6.2.1	Successo	Code Review	X
6.2.2	Fallito	Code Review	Non esiste cambio di password
6.2.3	Fallito	Code Review	Dipendente dal successo di 6.2.2
6.2.4	Fallito	Code Review	Non esistono controlli sulle password più comuni
6.2.5	Fallito	Code Review	UniClass prevede controlli complessi per la composizione di una password
6.2.6	Successo	Automated Test	X

ID	Esito	Testing Method	Note
6.2.7	Successo	Prova Browser	X
6.2.8	Successo	Prova Browser	X
6.3.1	Fallito	Code Review	Nessun controllo o anti-brute force
6.3.2	Successo	Code Review	X
6.4.1	N/A	Code Review	UniClass non permette password monouso ma randomiche.
6.4.2	Successo	Code Review	X
7.2.1	Successo	Code Review	Si crea la sessione solo dopo il login
7.2.2	Successo	Code Review	JSESSIONID unico token
7.2.3	Successo	Code Review	Secure Random usato
7.2.4	Fallito	Code Review	Non c'è invalidazione
7.4.1	Successo	Code Review	Si invalida la sessione
8.1.1	Successo	Doc e Code Review	X
8.2.1	Fallito	Code Review	X
8.2.2	N/A	Code Review	Non rilevante
8.3.1	Fallito	Code Review	X
9.1.1	N/A	Code Review	No JWT
9.1.2	N/A	Code Review	No JWT
9.1.3	N/A	Code Review	No JWT
9.1.4	N/A	Code Review	No JWT
10.4.1	N/A	Code Review	No OAUTH
10.4.2	N/A	Code Review	No OAUTH
10.4.3	N/A	Code Review	No OAUTH
10.4.4	N/A	Code Review	No OAUTH
10.4.5	N/A	Code Review	No OAUTH
11.1.3	N/A	Code Review	Nessuna cifratura
11.1.4	N/A	Code Review	Nessuna Cifratura
11.4.1	N/A	Code Review	Nessuna Cifratura
12.1.1	Fallito	Automated Test	Non presente TLS 1.2/1.3
12.2.1	Fallito	Automated Test	Non è stato previsto HTTPS inizialmente
12.2.2	Fallito	Automated Test	Handshake fallito poichè non previsto certificato TLS pubblicamente trusted
13.4.1	Successo	Automated Test	X
14.3.1	Successo	WSTG-CLNT-11	X
15.1.1	N/A	Documentazione	Non definito
15.2.1	N/A	Code Review e Documentazione	Non rilevante
15.3.1	Successo	Code Review	X

3.3 Security Measurement

Nella seguente sottosezione sarà possibile visionare lo stato attuale di Sicurezza del sistema UniClass, prima ancora di procedere con le procedure definite nella guida [2].



4 Acceptance Testing Post-Security Maintenance

4.1 Non-Functional Requirements

ID	Esito	Note
NFR4	Fallito	Per mancanza di risorse temporali ed economiche, si sospende lo sviluppo del Self-Healing System, ponendolo all'interno degli sviluppi futuri
NFR8	Successo	X
NFR9	Successo	X
NFR10	Successo	X
NFR11	Successo	X
NFR12	Successo	gli SDR che sono stati definiti sono all'interno dei DTL, nel dettaglio nel <i>Defect Management</i> e con esito nel presente documento
NFR13	Successo	X
NFR14	Successo	X
NFR15	Successo	X
NFR16	Successo	X
NFR17	Successo	X
NFR18	Successo	X

4.2 ASVS Requirements

ID	Esito	Testing Method	Note
1.2.1	Successo	WSTG-INPV-01/02	X
1.2.2	Successo	WSTG-INPV-02	X
1.2.4	Successo	WSTG-INPV-05	X
1.2.5	Successo	WSTG-INPV-12	X
1.3.1	Successo	WSTG-INPV-02	X
1.3.2	Successo	WSTG-CLNT-02	Non presente alcun eval o possibilità di esecuzione di codice dinamica
1.5.1	Successo	WSTG-INPV-07	Nessun problema con i parser XML
2.1.1	Successo	Documentazione	Nei TP e TCS è possibile visionare valori delle variabili e conseguente stato
2.2.2	Successo	CURL	X
2.3.1	Successo	CURL	X
3.2.1	Successo	Dev-Tools	X
3.2.2	Successo	WSTG-INPV-02	X
3.3.1	Fallito	Automated Test	Cookie di sessione senza flag secure, accettato come Risk Acceptance 4.3
3.4.1	Fallito	Automated Test	Strict-Transport-Security non presente, accettato come Risk Acceptance 4.3
3.4.2	Successo	Automated Test	X
3.5.1	Successo	WSTG-SESS-05	X
3.5.2	N/A	X	Nessun preflight
3.5.3	Successo	WSTG-INPV-06	X
4.1.1	Successo	Automated Test	X
4.4.1	Successo	WSTG-CONF	X
5.2.1	Successo	WSTG-BUSL-08	UniClass non prevede upload
5.2.2	Successo	WSTG-BUSL-08	UniClass non prevede upload
5.3.1	Successo	WSTG-BUSL-08	UniClass non prevede upload
5.3.2	Successo	WSTG-BUSL-08	UniClass non prevede upload
6.1.1	Successo	Documentazione	X
6.2.1	Successo	Code Review	X
6.2.2	Fallito	Code Review	Non esiste cambio di password, accettato per la motivazione presente in Risk Acceptance 4.3
6.2.3	Fallito	Code Review	Dipendente dal successo di 6.2.2, accettato per la motivazione presente in Risk Acceptance 4.3
6.2.4	Successo	Code Review	X
6.2.5	Fallito	Code Review	UniClass prevede controlli complessi per la composizione di una password, accettato per la motivazione presente in Risk Acceptance 4.3
6.2.6	Successo	Automated Test	X

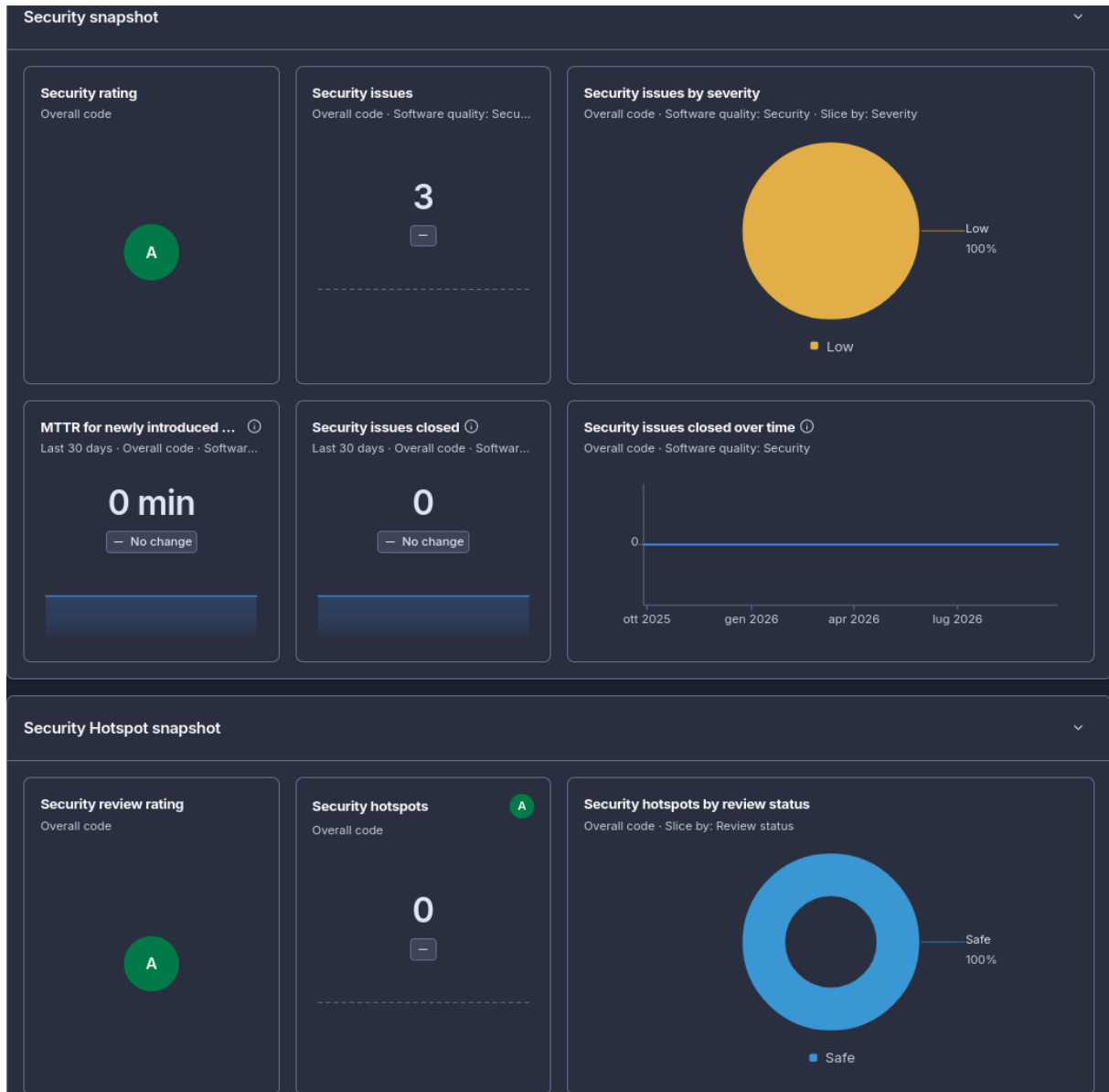
ID	Esito	Testing Method	Note
6.2.7	Successo	Prova Browser	X
6.2.8	Successo	Prova Browser	X
6.3.1	Successo	Code Review	X
6.3.2	Successo	Code Review	X
6.4.1	N/A	Code Review	UniClass non permette password monouso ma randomiche, accettato secondo le motivazioni presenti nel Risk Acceptance 4.3
6.4.2	Successo	Code Review	X
7.2.1	Successo	Code Review	Si crea la sessione solo dopo il login
7.2.2	Successo	Code Review	JSESSIONID unico token
7.2.3	Successo	Code Review	Secure Random usato
7.2.4	Fallito	Code Review	Non c'è invalidazione
7.4.1	Successo	Code Review	Si invalida la sessione
8.1.1	Successo	Doc e Code Review	X
8.2.1	Successo	Code Review	X
8.2.2	N/A	Code Review	Non rilevante
8.3.1	Successo	Code Review	X
9.1.1	N/A	Code Review	No JWT
9.1.2	N/A	Code Review	No JWT
9.1.3	N/A	Code Review	No JWT
9.1.4	N/A	Code Review	No JWT
10.4.1	N/A	Code Review	No OAUTH
10.4.2	N/A	Code Review	No OAUTH
10.4.3	N/A	Code Review	No OAUTH
10.4.4	N/A	Code Review	No OAUTH
10.4.5	N/A	Code Review	No OAUTH
11.1.3	N/A	Code Review	Nessuna cifratura
11.1.4	N/A	Code Review	Nessuna Cifratura
11.4.1	N/A	Code Review	Nessuna Cifratura
12.1.1	N/A	Automated Test	Non presente TLS 1.2/1.3
12.2.1	N/A	Automated Test	Non è stato previsto HTTPS inizialmente
12.2.2	N/A	Automated Test	Handshake fallito poichè non previsto certificato TLS pubblicamente trusted
13.4.1	Successo	Automated Test	X
14.3.1	Successo	WSTG-CLNT-11	X
15.1.1	N/A	Documentazione	Non definito
15.2.1	N/A	Code Review e Documentazione	Non rilevante
15.3.1	Successo	Code Review	X

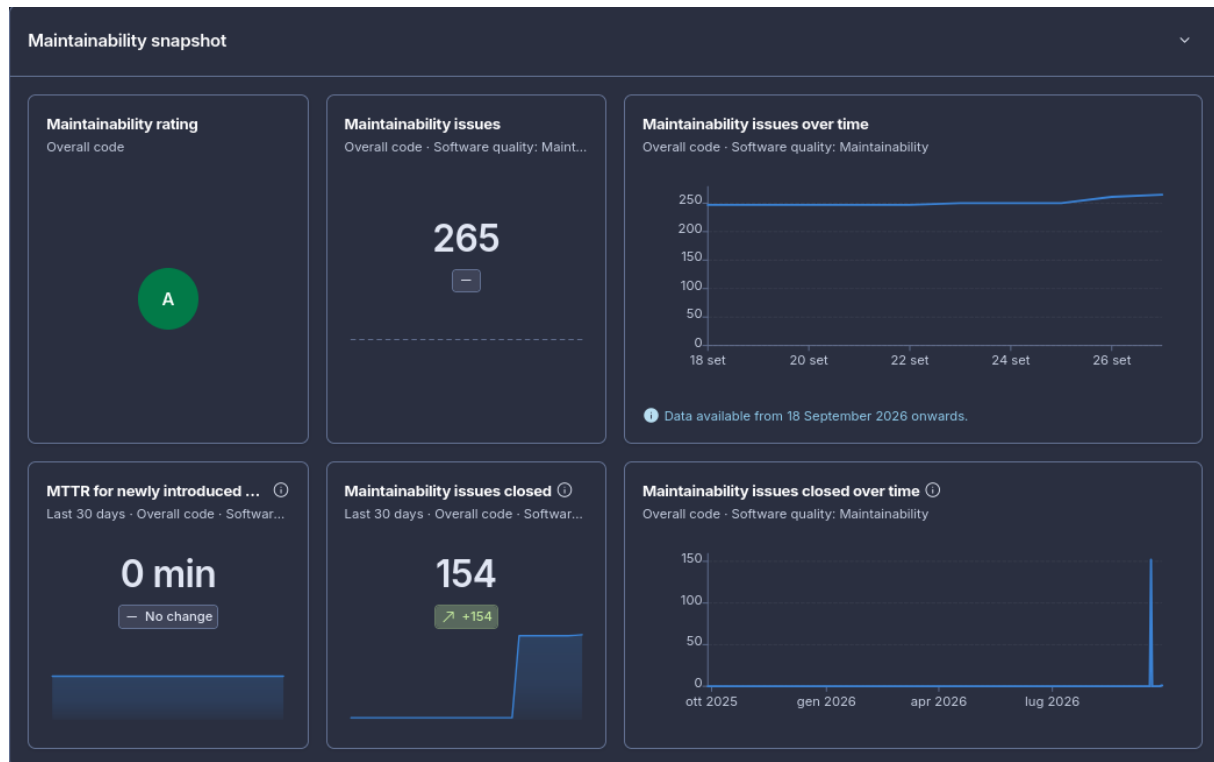
4.3 Requisiti Esclusi e Risk Acceptance

In questa sottosezione si visualizzeranno i requisiti esclusi, con eventuali motivazioni, e il Risk Acceptance, quindi l'accettazione del rischio derivato dal mancato soddisfacimento dei requisiti definiti

Requisito	Nota
3.3.1	Accettiamo il rischio e, data la mancanza di https (essendo toy project), non risolviamo il difetto che non fa soddisfare il requisito
3.4.1	Accettiamo il rischio e, data la mancanza di https (essendo toy project), non risolviamo il difetto che non fa soddisfare il requisito
6.2.2	L'utente, per definizione all'interno del RAD, non deve avere la possibilità di cambiare la propria password se non attraverso delle azioni del Personale Tecnico Amministrativo in uno scope, però, diverso da quello della piattaforma. Si accetta ovviamente il mancato soddisfacimento
6.2.3	Dato il mancato soddisfacimento del 6.2.2, si accetta il mancato soddisfacimento del 6.2.3
6.2.5	Essendo codici generati automaticamente, si accetta una composizione difficile (e registrabile) delle password definite. Si accetta il mancato soddisfacimento

4.4 SonarQube Analysis





5 AI-Usage

L'unione dell'utilizzo di sistemi di intelligenza artificiale per la codifica, documentazione, testing e integrazione con la Master Repository è definita in questa sezione, essendo il Report Finale del processo manutentivo. Si è utilizzata l'intelligenza artificiale per l'iniziale fix di problematiche relative alle tabelle in LaTeX e, successivamente, per la ricerca di test automatici per "Automated Tests".

Riferimenti bibliografici e Citazioni

- [1] OWASP Foundation. *Application Security Verification Standard*. URL: <https://owasp.org/projects/asvs>.
- [2] OWASP Foundation. *Web Security Testing Guide*. URL: <https://owasp.org/projects/web-security-testing-guide>.
- [3] OWASP Foundation. *What is OWASP SAMM?* URL: <https://owaspsamm.org/about/>.